Nmap-Based Network Reconnaissance on a Linux Target System

SEHBA ASHRAF BANGALATH

Cybersecurity Enthusiast | Network Reconnaissance | Web Application Analysis

Personal Practice Project (Controlled Lab Environment)

Tools Used: Nmap | Linux | Apache Tomcat

Objective: Identifying exposed services and analyzing system attack surfaces through network scanning and web enumeration techniques.

Table of Contents

1. Introduction 3
2. Project Objectives 4
3. Tools Used 5
4. Environment Details 5
5. Methodology 6
5.1 Reconnaissance Phases 6
5.1.1 Phase 1 — Host Discovery 6
5.1.2 Phase 2 — Full Port Scanning 6
5.1.3 Phase 3 — Service & Version Enumeration 7
5.1.4 Phase 4 — Web Application Analysis 7
5.1.5 Phase 5 — Validation & Verification 7
5.2 Methodology Summary 8
5.3 Ethical Considerations 8
6. Findings — Open Ports & Services 9
6.1 Scan Results 9
6.2 Scan Evidence 10
6.3 Detailed Observations 12
6.3.1 Port 22 — SSH (Secure Shell) 12
6.3.2 Port 80 — HTTP (Apache Web Server) 12
6.3.3 Ports 139 & 445 — SMB (Samba / NetBIOS) 12
6.3.4 Port 8009 — AJP (Apache JServ Protocol) 12
6.3.5 Port 8080 — Apache Tomcat 9.0.7 (Critical Finding) 13
6.4 Summary of Findings 13
6.5 Visual Analysis of Findings 14
6.6 Web Application Analysis (Key Findings) 15
7. Conclusion 16

1. Introduction

This project was undertaken as a self-directed initiative to develop and enhance practical cybersecurity competencies through hands-on experimentation within a controlled laboratory environment provided by TryHackMe. The primary objective was to perform foundational network reconnaissance on a Linux-based target system, systematically identifying exposed services, open ports, and potential security vulnerabilities within a legal and sandboxed setting.

Network reconnaissance lies at the core of effective cybersecurity practices. As the initial phase of ethical hacking methodology, it establishes the informational foundation upon which all subsequent analysis is built. This phase enables practitioners to map a system's network exposure, delineate its attack surface, and uncover weaknesses that may not be immediately visible through superficial examination. Beyond its procedural aspects, reconnaissance demands critical analytical thinking—requiring not only the ability to gather information, but also the capacity to interpret what that information reveals a system's overall security posture.

The significance of this exercise extends beyond purely technical skill development. What makes network reconnaissance particularly valuable is its dual nature: each discovered open port or exposed service provides both offensive insight and a defensive implication. Every finding reflects a potential misconfiguration, unnecessary exposure, or unpatched service that could be exploited by an adversary, thereby highlighting areas requiring mitigation. Engaging with this process independently reinforced not only technical proficiency, but also a disciplined and methodical approach to cybersecurity analysis. Ultimately, this project served to cultivate a mindset grounded in curiosity, rigor, and ethical responsibility—qualities essential to effective practice in the cybersecurity domain.

2. Project Objectives

The objectives of this project were designed to build progressively, with each phase informing the next to form a coherent and methodical assessment of the target system's security posture. Rather than treating each task in isolation, the work was structured to mirror the systematic approach used in real-world cybersecurity assessments — moving from broad discovery through to risk analysis.

- To perform foundational network reconnaissance on a Linux-based target system within a controlled laboratory environment
- To identify open ports and active network services, establishing the boundaries of the system's attack surface
- To determine service versions and configuration details, assessing the degree of network exposure present
- To analyze potential security risks arising from discovered services and evaluate their real-world implications
- To develop practical, hands-on proficiency in core cybersecurity assessment techniques including network scanning, service enumeration, and attack surface analysis

Collectively, these objectives were oriented toward building the disciplined, methodical thinking that effective cybersecurity practice demands — translating controlled laboratory experience into skills and insights applicable to real-world security assessment scenarios.

3. Tools Used

The following tools were selected for their relevance to professional-grade network reconnaissance and their widespread use in real-world cybersecurity practice:

Tool	Purpose
Nmap	Primary tool for network scanning, open port discovery, and service enumeration
macOS Terminal (MacBook Air M1)	Local environment used to execute scanning commands and interact with the target system
Web Browser	Used to access and manually analyze web services identified as running on the target system

4. Environment Details

Parameter	Details
Platform	TryHackMe
Target System	Linux-based virtual machine
Target IP Address	10.146.187.217
Environment Type	Controlled, sandboxed cybersecurity lab

The TryHackMe laboratory environment was specifically designed to replicate realistic network scenarios without the risks associated with live system interaction. By operating within this sandboxed infrastructure, the project enabled genuine practical exposure to cybersecurity assessment techniques - reinforcing both technical proficiency and the ethical boundaries that govern responsible security practice. This separation between simulation and production environments is not merely a precaution; it is a foundational principle of ethical hacking and professional penetration testing methodology.

5. Methodology

The reconnaissance assessment was conducted using a structured, phased methodology designed to systematically map the target system's network exposure from the ground up. Each phase was sequenced deliberately - progressing from broad discovery through to granular service analysis - to ensure no aspect of the target's attack surface was overlooked. This approach mirrors the information gathering and reconnaissance stages outlined in professional penetration testing frameworks, including the **Penetration Testing Execution Standard (PTES)** and **OWASP Testing Methodology**.

All scanning and enumeration activities were performed exclusively using **Nmap (Network Mapper)** - the industry-standard tool for network reconnaissance - within the fully authorized and sandboxed TryHackMe laboratory environment.

5.1 Reconnaissance Phases

5.1.1 Phase 1 — Host Discovery

Prior to any scanning activity, the availability and reachability of the target host was confirmed. An ICMP-based ping scan was issued to verify that the target system at 10.146.187.217 was active and responsive on the network. Establishing host availability is a non-negotiable prerequisite in any professional assessment - proceeding without it risks generating inaccurate or meaningless results.

Objective: Confirm target is live and reachable before committing to deeper scanning activity.

5.1.2 Phase 2 — Full Port Scanning

With host availability confirmed, a comprehensive TCP port scan was conducted across the target system. Rather than limiting the scan to commonly known ports, a full-range scan was performed to ensure complete coverage — capturing any services running on non-standard or unexpected ports. This phase produced the foundational attack surface map from which all subsequent analysis was derived.

Objective: Identify all open TCP ports and establish the complete boundary of the target's network exposure.

5.1.3 Phase 3 — Service & Version Enumeration

Each open port identified in Phase 2 was subjected to detailed service and version detection. This phase moved beyond surface-level port discovery to determine precisely what software was running on each exposed port, including service names, version numbers, and available operating system details. Service version information is particularly significant in vulnerability assessment, as outdated software versions frequently correspond to publicly documented exploits and known CVEs (Common Vulnerabilities and Exposures).

Objective: Identify running services and software versions to assess the target's vulnerability exposure.

5.1.4 Phase 4 — Web Application Analysis

Web services identified during enumeration were accessed manually via browser for direct inspection. This phase involved observing publicly exposed web interfaces, identifying running web applications, and noting any information disclosed through default pages, directory listings, or misconfigured services. Unintended information disclosure through web interfaces represents one of the most frequently encountered vulnerabilities in real-world network assessments.

Objective: Manually inspect exposed web services for accessible interfaces and unintended information disclosure.

5.1.5 Phase 5 — Validation & Verification

Upon completing all scanning and enumeration phases, a final round of targeted scans was conducted to cross-validate all findings. This verification process ensured the accuracy and reproducibility of results, eliminated potential false positives, and confirmed that the full scope of the target's attack surface had been captured. In professional penetration testing

engagements, result validation is a mandatory step - distinguishing reliable, reportable findings from unconfirmed assumptions.

Objective: Confirm accuracy of all findings and ensure completeness of the reconnaissance assessment.

5.2 Methodology Summary

Phase	Activity	Tool Used
Phase 1	Host Discovery & Availability Check	Nmap
Phase 2	Full TCP Port Scanning	Nmap
Phase 3	Service & Version Enumeration	Nmap
Phase 4	Web Application Analysis	Web Browser
Phase 5	Validation & Verification	Nmap

5.3 Ethical Considerations

All reconnaissance activities described in this methodology were conducted strictly within the authorized boundaries of the TryHackMe laboratory environment. No scanning, probing, or enumeration was directed at any system outside of the designated target. This reflects a core principle of professional and ethical security practice — that all assessment activities must be explicitly authorized, clearly scoped, and conducted with full respect for legal and ethical boundaries. Adherence to these principles is not simply good practice; it is the foundation upon which trustworthy cybersecurity professionals operate.

6. Findings — Open Ports & Services

The Nmap scan conducted against the target system at 10.146.187.217 returned a definitive set of results identifying all active ports and their corresponding services. The findings reveal a system running multiple simultaneous network services — each representing a discrete point of network exposure and a potential vector for further vulnerability analysis.

Command executed:

```
nmap -Pn 10.146.187.217
```

Nmap Version: 7.99 | **Scan Duration:** 32.97 seconds | **Host Latency:** 0.14s

6.1 Scan Results

Port	Protocol	Service (Raw)	Description
22	TCP	ssh	Secure Shell — remote login and administration
80	TCP	http	Apache HTTP Web Server
139	TCP	netbios-ssn	SMB over NetBIOS — legacy file sharing
445	TCP	microsoft-ds	Samba — direct file and printer sharing over TCP/IP
8009	TCP	ajp13	Apache JServ Protocol — internal Tomcat connector
8080	TCP	http-proxy	Apache Tomcat — web application server

994 closed TCP ports were detected (conn-refused), confirming that the 6 ports above represent the complete active attack surface of the target system.

6.2 Scan Evidence

Figure 1 — Full Nmap Port Scan

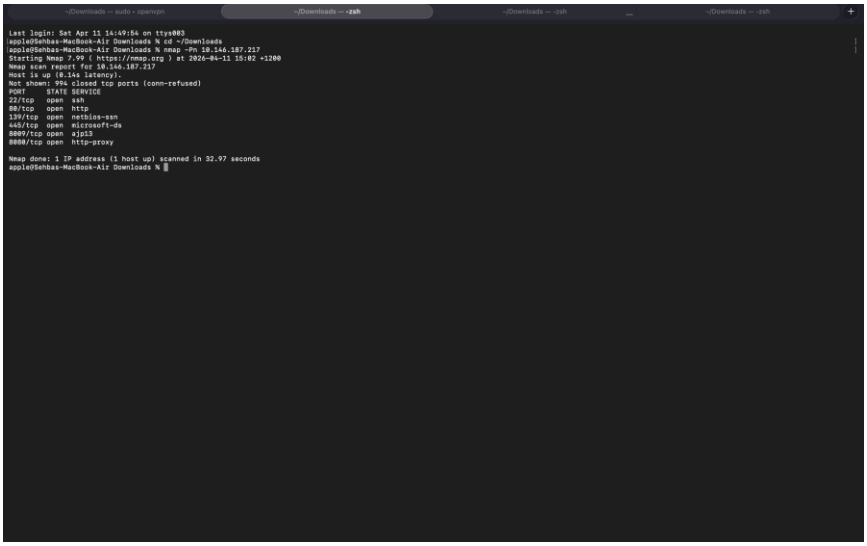

Figure 1: *Nmap -Pn scan output confirming 6 open TCP ports on target 10.146.187.217, executed from macOS Terminal on MacBook Air M1. Scan completed in 32.97 seconds with a host latency of 0.14s.*

Figure 2 — SMB Enumeration Scan

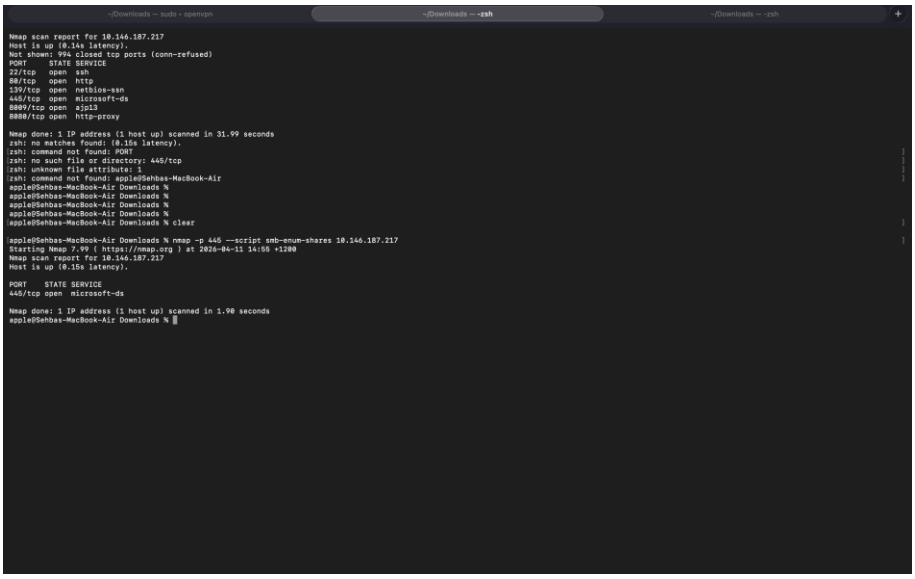

Figure 2: Targeted Nmap scan against port 445 using the --script smb-enum-shares flag, confirming an active microsoft-ds service. The SMB enumeration script execution validates the presence of the Samba file-sharing service on the target system.

Figure 3 — Apache Tomcat Web Interface (Port 8080)

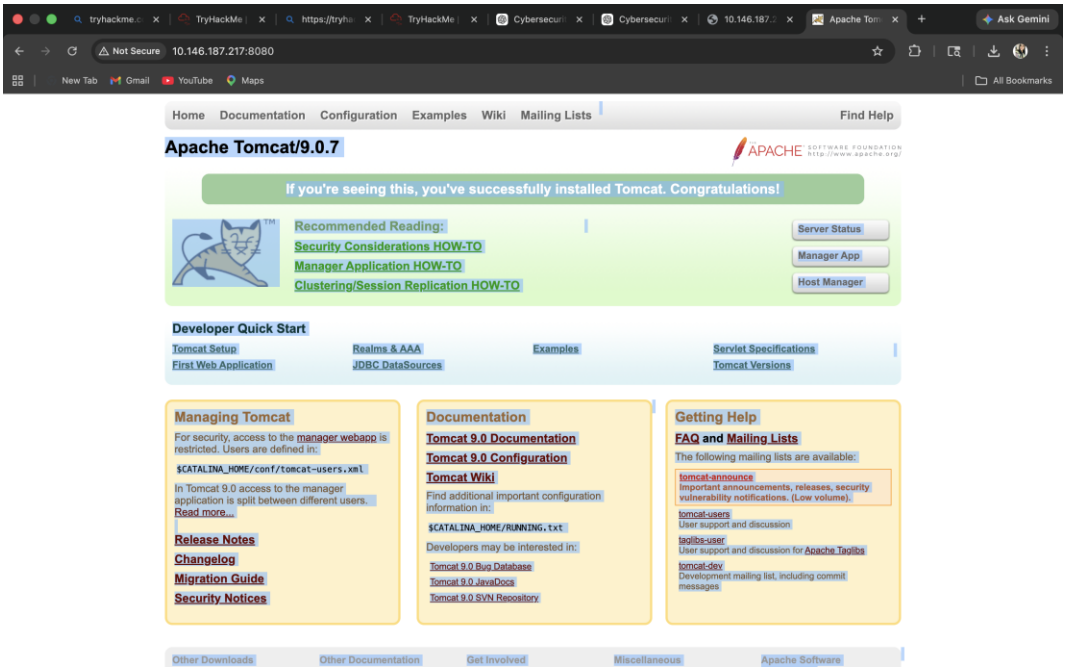

Figure 3: *Browser access to 10.146.187.217:8080 confirming a live* ***Apache Tomcat 9.0.7*** *default installation page. The version disclosure — Tomcat 9.0.7 — is a significant finding, as this specific version carries known security vulnerabilities. The presence of accessible* ***Manager App*** *and* ***Host Manager*** *buttons further indicates potential administrative interface exposure.*

Figure 4 — Tomcat Manager Authentication Prompt (Port 8080/manager/html)

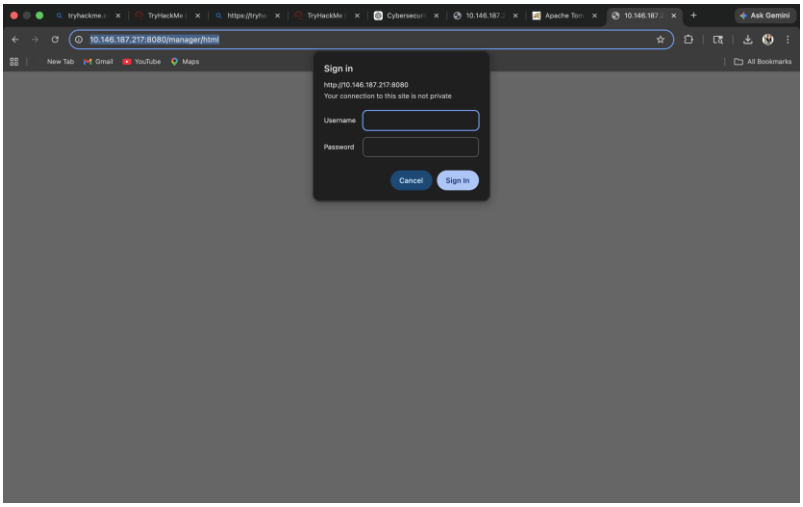

Figure 4: *Direct browser navigation to 10.146.187.217:8080/manager/html reveals an exposed* ***Tomcat Manager login interface****. The accessibility of this endpoint — even behind an authentication prompt — is a critical finding. The Tomcat Manager is a high-value target in penetration testing, as weak or default credentials (tomcat:tomcat, admin:admin) frequently grant full application deployment access, enabling remote code execution in real-world scenarios.*

6.3 Detailed Observations

6.3.1 Port 22 — SSH (Secure Shell)

The presence of an active SSH service indicates that the target accepts remote login connections. While SSH is an encrypted protocol, its exposure represents a significant access point. Without proper hardening — key-based authentication, fail2ban rate limiting, or port restriction — SSH services are frequently targeted by brute-force and credential stuffing attacks.

6.3.2 Port 80 — HTTP (Apache Web Server)

An Apache HTTP web server was confirmed running on standard port 80, actively serving web content. Web server exposure significantly broadens the attack surface, introducing potential vulnerabilities associated with misconfigurations, outdated software versions, and unprotected directories.

6.3.3 Ports 139 & 445 — SMB (Samba / NetBIOS)

The simultaneous presence of both SMB ports — confirmed via targeted enumeration scan (Figure 2) — indicates an active Samba file-sharing service. SMB services are historically among the most exploited network services, having been implicated in critical vulnerabilities including **EternalBlue (MS17-010)** and the **WannaCry ransomware campaign**. Their presence on a network-accessible system warrants serious scrutiny.

6.3.4 Port 8009 — AJP (Apache JServ Protocol)

The exposure of port 8009 reveals an active AJP13 connector — an internal communication protocol between a front-end web server and back-end Tomcat instance. Its network exposure is particularly noteworthy; the **Ghostcat vulnerability (CVE-2020-1938)** demonstrated that exposed AJP connectors can allow unauthenticated attackers to read sensitive files or achieve

remote code execution. This port should never be publicly accessible in any production environment.

6.3.5 Port 8080 — Apache Tomcat 9.0.7 (Critical Finding)

Browser inspection of port 8080 confirmed **Apache Tomcat version 9.0.7** running with its default installation page publicly accessible (Figure 3). Two compounding vulnerabilities were identified:

- **Version disclosure** — Tomcat 9.0.7 is an outdated release with documented CVEs
- **Exposed Manager interface** — Direct navigation to /manager/html (Figure 4) confirmed that the Tomcat Manager application is accessible without network-level restriction, presenting only an HTTP Basic Authentication prompt as its sole defense

In real-world penetration testing, an exposed Tomcat Manager endpoint is frequently leveraged to deploy malicious WAR files, achieving full remote code execution on the target system. This represents the highest-severity finding of this assessment.

6.4 Summary of Findings

Finding	Detail
Total Open Ports Identified	6
Web Services Detected	2 (Ports 80 & 8080)
File Sharing Services Detected	2 (Ports 139 & 445)
Remote Access Services Detected	1 (Port 22)
Internal Protocol Exposed	1 (Port 8009 — AJP)
Critical Version Disclosure	Apache Tomcat 9.0.7 confirmed
High-Value Attack Surface	Tomcat Manager /manager/html accessible
Overall Risk Assessment	Elevated — multiple critical services exposed

The scan results collectively indicate a target system with a broad and critically exposed network profile. The most significant finding is the combination of an outdated Apache Tomcat 9.0.7 installation with a publicly accessible Manager interface — a pairing that, in a real-world scenario, would represent a near-immediate path to full system compromise. These findings reinforce a fundamental principle of network security: every unnecessary open port is an

unnecessary risk, and every exposed management interface without robust access controls is an open door.

6.5 Visual Analysis of Findings

The following visualizations provide a graphical representation of the scan results, illustrating the distribution of open ports by service type and their corresponding risk severity levels.

Figure 5 — Attack Surface Dashboard

Figure 5: Visual risk assessment of the 6 identified open ports, categorized by severity — Critical, High, and Medium — based on known vulnerabilities and real-world exploit history associated with each exposed service.

6.6 Web Application Analysis (Key Findings)

During reconnaissance, an Apache Tomcat 9.0.7 web application was identified running on port 8080. The default Tomcat landing page was publicly accessible, along with clear version disclosure, which increases exposure to known vulnerabilities and simplifies targeted exploitation.

A key security concern was the exposure of the **/manager/html Tomcat Manager interface**. While authentication is required, the presence of this administrative endpoint on a network-accessible interface significantly expands the attack surface, particularly in environments where weak or default credentials may exist.

If compromised, this interface could allow an attacker to deploy malicious applications, potentially leading to **remote code execution (RCE)** and full server compromise depending on system configuration and privilege boundaries.

This observation highlights several critical security gaps:

- Public exposure of version information
- Lack of network-level restriction on administrative interfaces
- Risk of weak or default authentication practices
- Increased attack surface due to unnecessary service exposure

This represents a **critical web application misconfiguration**, reinforcing the importance of secure-by-default deployments and strict access control for management interfaces.

7. Conclusion

This exercise demonstrated how quickly a system's attack surface expands when services are left exposed with default configurations and outdated software.

The presence of multiple open services, combined with an exposed Apache Tomcat 9.0.7 instance and accessible administrative interface, highlights how misconfigurations at the application layer can escalate into critical security risks.

Even without active exploitation, the findings clearly show that weak hardening practices—such as exposed management endpoints, version disclosure, and unnecessary service exposure—can significantly increase the likelihood of compromise in real-world scenarios.

This project strengthened my practical understanding of network reconnaissance and reinforced the importance of secure configuration, service minimization, and strict access control in system security.